DIGNITAS — PS05 ADAPTIVE AUTHENTICATION GATEWAY

HACKATHON FINAL DEFENSE
Team of 4 Pitch Deck

A Comprehensive Judging Presentation, 4-Speaker Script, Live Attack Demo Guide & Q&A; Battlecards

Executive Mission: DIGNITAS solves **Problem Statement PS05** by replacing static, high-friction 2FA with an intelligent, explainable, sub-10ms risk engine. Legitimate users authenticate with **zero friction**, while malicious automated bots, credential stuffers, and account takeovers face a mathematically graduated **5-Tier Threat Mitigation Policy**. This document coordinates a polished **7-minute presentation** distributed across 4 team members.

1. Team Roster & Stage Allocation (4 Speakers)

Speaker & Role	Time Slot	Core Theme & Key Responsibilities	Live Screen / Demo Action
Speaker 1 **Team Lead & Visionary**	**0:00 - 1:30** (90 sec)	**Problem PS05 Framing**: The 2FA fatigue dilemma, credential stuffing epidemic, and DIGNITAS zero-friction vision.	Opens **Overview Site** (/landing), points to Problem Statement and Solution Matrix.
Speaker 2 **Risk Engine Architect**	**1:30 - 3:15** (105 sec)	**5-Tier Adaptive Architecture**: Mathematical scoring, risk weights (+45 dev, +25 country, +35 attempts), explainability.	Slides toggles in **Live Matrix Simulator**; demonstrates dynamic score shifts across tiers.
Speaker 3 **Live Demo Master**	**3:15 - 5:15** (120 sec)	**Live Attack Demonstrations**: Executes Scenarios 1, 2, 4, 6 & 8 in the live gateway; shows OTP toast & phone sim.	Operates **Interactive Gateway** (/dashboard); demonstrates CAPTCHA, 6-box OTP, and instant blocks.
Speaker 4 **SOC & Intelligence Lead**	**5:15 - 6:45** (90 sec)	**SOC Intelligence & Data Integrity**: Real-time ledger, ACID SQLite inspector, enterprise SLA (<10ms), cross-app sync.	Switches to **SOC Threat Center** (/dashboard/soc.html); inspects SQL database tables and user locks.
All 4 Members **Panel Defense**	**6:45 - 8:00+** (Q&A;)	**Judges' Q&A; Defense**: Handles technical objections on privacy, latency, bypass vectors, and enterprise scalability.	Answers directed based on domain specialty (Speaker 1: Product, 2: Math, 3: UX, 4: Backend).

SPEAKER 1: PROBLEM FRAMING, THE 2FA PARADOX & THE DIGNITAS VISION

0:00 – 1:30 (90 seconds)

Opening Hook & Spoken Script:

"Respected judges, every day millions of legitimate users suffer through frustrating SMS codes and CAPTCHAs, while sophisticated automated bots and credential stuffers steal billions of dollars using stolen passwords. Security teams face an impossible dilemma: **maximum friction that kills user retention, or minimum friction that invites disaster**."

"Static 2FA is fundamentally broken. Today, our team is proud to introduce **DIGNITAS** — an Adaptive Authentication and Suspicious Login Detection Gateway engineered specifically for Problem Statement PS05. DIGNITAS replaces guesswork with a **sub-10ms, mathematically explainable risk engine**. Legitimate users glide through with zero friction, while threats are graduated across a rock-solid 5-tier mitigation policy."

Screen & Demo Cues for Speaker 1:

- **[0:15]** Stand beside screen showing **http://localhost:8000/landing/**.
- **[0:40]** Scroll smoothly to Section #problem to highlight the 3 core failures of legacy systems.
- **[1:15]** Point to the Solution Matrix card and transition to Speaker 2: *'Now, my teammate will explain how our mathematical engine evaluates risk in under 10 milliseconds.'*

SPEAKER 2: MATHEMATICAL RISK SCORING & THE 5-TIER ADAPTIVE ENGINE

1:30 – 3:15 (105 seconds)

Core Spoken Script:

"Thank you, Speaker 1. At the heart of DIGNITAS is our **Explainable Contextual Risk Scoring Engine**. Instead of opaque black-box machine learning models that compliance auditors reject, every single login evaluation produces an integer score from 0 to 100, backed by explicit, itemized mathematical reasons."

"We analyze multi-dimensional contextual signals: **hardware device fingerprints, geographic country shifts, impossible velocity calculations (e.g., India to USA in 15 minutes), Tor exit nodes, unusual hour deviations, and cross-application threats**. Most importantly, we redesigned the mitigation hierarchy into a defensible **5-Tier Architecture**:"

- **Tier 1 (0–29 pts): Frictionless Allow** — Standard password check. Zero user friction for familiar baseline logins.
- **Tier 2 (30–44 pts): Turnstile CAPTCHA Challenge** — Neutralizes rapid brute-force bots without locking out legitimate humans.
- **Tier 3 (45–59 pts): Contextual Challenge & Device Trust** — For new unrecognized devices (+45 pts), prompts 6-box Email OTP with optional 30-day device enrollment.
- **Tier 4 (60–79 pts): High-Threat Quarantine & Out-of-Band Push** — For impossible travel (+70 pts), freezes session in isolated quarantine pending mobile push approval.
- **Tier 5 (80–100 pts): Automated Hard Block & Breach Protocol** — For account takeovers, honeytoken traps, and blacklisted IPs. Blocks login, adds IP to SQLite blacklist, and sends urgent password reset alert email.

Screen & Demo Cues for Speaker 2:

- **[1:45]** Scroll to **Section #simulator** in the Overview site.
- **[2:10]** Click 'New Device Mismatch (+45 pts)' checkbox live; show gauge move to 45 (Tier 3: Step-Up OTP).
- **[2:40]** Click 'Tor Proxy' (+25) and 'Unusual Hours' (+10); show gauge jump to 80 (Tier 5: Critical Block).
- **[3:05]** Hand off to Speaker 3: *'Now, let us watch these 5 tiers defend live applications under real attack.'*

SPEAKER 3: LIVE GATEWAY DEMONSTRATION & ATTACK SCENARIOS

3:15 – 5:15 (120 seconds)

Core Spoken Script:

"Thank you, Speaker 2. You are looking at our **Live Border-Control Adaptive Gateway** running at /dashboard. Notice our dual-app toggle: we protect both a high-security banking portal (Apex Bank) and a consumer social network (Pulse Social). Let us execute our live scenarios using our quick keyboard hotkeys:"

"**Press Key 1: Scenario 1 (Normal Familiar Login).** Alice logs in from her trusted laptop in Delhi. The risk score is exactly 0. The gateway issues a JWT token instantly with zero friction in just 4.5 milliseconds."

"**Press Key 2: Scenario 2 (First-Time Device Challenge).** Alice signs in from an unrecognized mobile device. Risk score jumps to 45 (Tier 3). Notice the slide-in security toast and our interactive 6-box OTP challenge. We enter the OTP code 482910, check *Trust this device for 30 days*, and the device is enrolled into our trusted SQL database."

"**Press Key 4: Scenario 4 (Brute-Force Attack Burst).** An attacker injects 5 rapid password attempts. The gateway calculates an attempt velocity penalty and immediately triggers Cloudflare Turnstile CAPTCHA (Tier 2: 35 pts), blocking the automated bot script in its tracks."

"**Press Key 6: Scenario 6 (Honeytoken Decoy Trap).** An attacker probes our system targeting decoy account backup_admin. The gateway triggers a 100-point hard block, terminates the connection, and automatically blacklists the attacker IP into SQLite."

"**Press Key 8: Scenario 8 (Impossible Travel).** Bob logged into Delhi 15 minutes ago; now an attacker presents valid credentials from New York. That requires Mach-4 supersonic flight speed! DIGNITAS calculates impossible velocity, assigns Score 70 (Tier 4), and isolates the session in Quarantine."

Screen & Demo Cues for Speaker 3:

- **[3:20]** Switch active browser tab to **http://localhost:8000/dashboard/**.
- **[3:35]** Press **Key 1** $\rightarrow$ Show green gauge, 'Score 0', frictionless success banner.
- **[4:00]** Press **Key 2** $\rightarrow$ Show yellow gauge 'Score 45', 6-box modal pops up; enter OTP, click 'Trust device'.
- **[4:30]** Press **Key 4** $\rightarrow$ Show Cloudflare Turnstile CAPTCHA challenge box render.
- **[4:55]** Press **Key 6** $\rightarrow$ Show red gauge 'Score 100 Hard Block' and judge's iPhone simulator alert toast.
- **[5:10]** Click top nav link Security Operations (SOC Feed) ■ and hand over to Speaker 4.

SPEAKER 4: SOC THREAT TELEMETRY, ACID SQL LEDGER & ENTERPRISE SLA

5:15 – 6:45 (90 seconds)

Core Spoken Script:

"Thank you, Speaker 3. While users experience seamless security, enterprise security analysts need total visibility. This is our **Security Operations Center (SOC)** running at /dashboard/soc.html. Every login attempt is captured in an **immutable, real-time audit ledger**."

"Notice our live ACID Database Inspector tab. We use an enterprise-grade SQLite relational engine with foreign keys and indexing. Security admins can directly inspect the login_events table, known_devices hardware table, and the automated flagged_ips blacklist table. If an account is actively targeted, our Emergency Kill Switch allows SOC analysts to lock or unlock any user in 1 click with zero downtime."

"**Performance & Verification Metrics:** In our comprehensive test suite of 12 unit tests and 8 end-to-end attack scenarios, DIGNITAS achieved a **100% detection rate**, **0.0% false positives** on legitimate baselines, and an average decision latency of **8.67 milliseconds** — well under our strict 100ms enterprise SLA requirement."

"In conclusion, DIGNITAS proves that organizations do not have to choose between user experience and uncompromising security. Thank you, and our entire team is now eager to take your questions!"

Screen & Demo Cues for Speaker 4:

- **[5:20]** Display **http://localhost:8000/dashboard/soc.html**.
- **[5:45]** Click 'Database Explorer' tab; show live record counts and click flagged_ips table.
- **[6:15]** Point to 'Average Latency: 8.67 ms' and 'Zero False Positives' badges on the live dashboard.
- **[6:40]** All 4 team members step forward together, make eye contact with judges for Q&A.;

2. Official 5-Tier Adaptive Threat Matrix

Tier & Risk Score	Trigger Signals & Conditions	Adaptive Enforcement Action	UX Impact & Security Rationale
Tier 1: Minimal **0 – 29 pts**	Trusted hardware, known IP/subnet, typical working hours, familiar country.	**Frictionless Allow** Standard Argon2 password check; JWT issued.	Zero user friction. Seamless entry for legitimate daily workflow.
Tier 2: Low **30 – 44 pts**	Rapid brute-force attempts (2–5 failures), cross-app threat correlation (+35 pts).	**Cloudflare Turnstile CAPTCHA** Enforces cryptographic proof-of-work.	Filters high-speed bot scripts without frustrating legitimate humans with OTP.
Tier 3: Medium **45 – 59 pts**	New unrecognized device (+45 pts), mild time anomaly, unverified browser.	**Contextual Step-Up MFA** 6-Box Email OTP + 30-Day Device Trust.	Verifies possession of primary mailbox; binds hardware to prevent future friction.
Tier 4: High **60 – 79 pts**	Impossible travel velocity (e.g., India $\rightarrow$ US in 15m), multiple anomalies.	**Session Quarantine** Out-of-band mobile verification challenge.	Isolates session from sensitive resources until authorized out-of-band.
Tier 5: Critical **80 – 100 pts**	Honeytoken target (backup_admin), blacklisted IP, Tor ATO combo.	**Hard Block + Auto Blacklist** Source IP banned; Emergency breach email sent.	Immediate threat termination; provides one-click password reset link to victim.

3. Judges' Q&A; Battlecards (Anticipated Objections & Answers)

Be prepared for these 6 technical challenges from the judging panel. Speak with confidence and cite these exact mechanisms:

Q1: Why not enforce MFA for every single login? Isn't mandatory MFA safer? **Lead: Speaker 1 / 2**

Winning Answer: Mandatory MFA causes severe user fatigue, high drop-off rates (up to 40% in consumer apps), and massive SMS/provider costs. More critically, attackers bypass static MFA using prompt bombing, real-time phishing proxies (Evilginx), and SIM swapping. DIGNITAS applies defense-in-depth: zero friction for trusted sessions, but instant graduated escalation when signals deviate, making targeted attacks far harder to execute.

Q2: Can't sophisticated attackers easily spoof HTTP headers and IP addresses? **Lead: Speaker 2 / 4**

Winning Answer: IP spoofing over TCP three-way handshake is mathematically impossible for stateful HTTP sessions because sequence numbers cannot be completed without receiving response packets. Additionally, our device fingerprinting is multi-attribute: we correlate hardware screen geometry, WebGL rendering hashes, CPU concurrency, platform architecture, and TLS client fingerprints. Spoofing one header does not bypass our compound risk score.

Q3: How do you achieve sub-10ms decision latency? Does this scale? **Lead: Speaker 2 / 4**

Winning Answer: Our average decision latency is 8.67ms. We achieve this because our risk calculation is strictly local, in-memory, and deterministic. All contextual weights and historical baseline calculations run via indexed SQLite queries with zero external network blocking. In production, Redis caching can further reduce latency to sub-2 milliseconds for millions of concurrent sessions.

Q4: What if an attacker attempts impossible travel using a residential proxy in the user's city? **Lead: Speaker 3 / 2**

Winning Answer: If an attacker uses a local proxy, the geographic country signal might not trigger, but the unrecognized hardware device mismatch (+45 pts) still immediately activates Tier 3 Contextual MFA. If they also guess incorrect passwords or attack during unusual hours (3 AM), compound score penalties immediately push the session into Tier 4 Quarantine or Tier 5 Block.

Q5: How does the Cross-Application Threat Correlation work across different apps? **Lead: Speaker 4 / 3**

Winning Answer: Our centralized risk engine indexes security events by normalized user identity across all enterprise applications (e.g. Apex Bank and Pulse Social). When a high-risk security incident or brute-force burst occurs on Apex Bank, any login attempt on Pulse Social within the correlation window inherits a +35 point penalty, neutralizing lateral movement attacks.

Q6: What about user privacy, GDPR compliance, and telemetry data storage? **Lead: Speaker 4 / 1**

Winning Answer: DIGNITAS follows strict data minimization principles. We do not store invasive keystroke recordings or precise GPS location tracks. Telemetry is limited to coarse country/city geolocation and hashed device signatures. Furthermore, our automated background task enforces a 30-day retention window, purging stale event telemetry to ensure GDPR compliance.

4. Keyboard Shortcut Cheatsheet for Speaker 3

Key	Scenario Name	Target App	Score	Enforced Action
1	Normal Familiar Login	Apex Bank	**0**	Frictionless Allow (JWT)
2	First-Time Device Mismatch	Apex Bank	**45**	Tier 3 Email OTP + Device Trust
3	Foreign Tor Attack at 3 AM	Apex Bank	**100**	Tier 5 Critical Hard Block
4	Brute-Force Password Burst	Apex Bank	**30**	Tier 2 Turnstile CAPTCHA
5	Cross-App Threat Correlation	Pulse Social	**40**	Tier 2 Elevated Challenge
6	Honeytoken Trap (backup_admin)	Apex Bank	**100**	Tier 5 Block & IP Flagged in DB
7	Baseline Adaptation (Enrolled)	Apex Bank	**0**	Frictionless Allow (Post-Enroll)
8	Impossible Travel (IN $\rightarrow$ US)	Apex Bank	**70**	Tier 4 Quarantine Verification